

17.12.2025

שיעור 1

מסר מפתח של השיעור:

CISO טוב לא שואל "האם יש חולשה",
אלא "איזה סיכון זה יוצר לפעילות העסקית, ומה האלטרנטיבות."

1. תפיסת היסוד של – CISO תפקיד ולא רק טכנולוגיה

- תפקיד ה CISO - אינו לעצור את הארגון, אלא לאפשר פעילות עסקית בצורה בטוחה.
- בהשוואה לרכב- אבטחת מידע היא "בלמים"
- ככל שהבלמים טובים יותר – הארגון יכול "לנסוע מהר יותר."
- אין ולא תהיה אבטחה של 100% – המטרה היא ניהול סיכונים, לא ביטול מוחלט שלהם.

2. נכסים ארגוניים – מה באמת חשוב

- נכס ≠ מחשב / שרת / תוכנה.
- נכס ארגוני אמיתי = פעילות עסקית שמכניסה כסף לארגון.
- מערכות, מידע ואנשים – הם אמצעים תומכים בנכס, לא הנכס עצמו.
- (*חשוב למצגת מנהלים) הנהלה בכירה מתעניינת ב:
 - פגיעה בפעילות
 - אובדן הכנסות
 - פגיעה במוניטין
 - רגולציה וקנסות

3. חולשה, איום וסיכון – ההבחנה הקריטית

חולשה (Vulnerability)

- כשל טכנולוגי / תהליכי / אנושי שניתן לניצול.
- לא כל חולשה מעניינת –רק כזו שמובילה לפגיעה בנכס.

איום (Threat)

- גורם או תרחיש שעלול לנצל חולשה.
- איום הוא כללי וגבוה ("דלף מידע", "תקיפה").

סיכון (Risk)

- איך האיום מתממש בפועל.
- מוגדר תמיד ע"י:
 - הסתברות
 - השפעה (נזק)
- סיכון = פגיעה (נזק) אפשרית (סבירות/ הסתברות) בנכס ארגוני.

4. הערכת חולשות – לא לפי "ציון", אלא לפי הקשר עסקי

- <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?name=CVE-2021-44228&vector=AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H&version=3.1&source=>
- NIST (Common Vulnerability Scoring System Calculator)
- CVE / CVSS נותנים **ציון טכני**, לא החלטה ניהולית.
- ציון 10/10 ≠ בהכרח טיפול מיידי.
- שאלות שמנהל אבטחת מידע צריך לשאול:
 - איפה החולשה קיימת?
 - האם המערכת חשופה החוצה?
 - האם היא תומכת בנכס קריטי?
 - האם יש ניטור / פיצוי / בקרה?

5. כלים ותוקפים – העולם פתוח

- תוקפים משתמשים בכלים פתוחים:
 - Shodan
 - חיפוש גרסאות פגיעות
 - מצלמות, שרתים DB, פתוחים
- עצם פרסום חולשה ← מאפשר לתוקף לאתר מטרות בקלות.
- לבן:
 - לדעת "מה יש לי בארגון"
 - לדעת "מה חשוף החוצה"
 - לדעת "מה לא מתוחזק"

6. מערכות ישנות ו-Legacy- דילמה ניהולית

- ידיעת החולשה **לא תמיד פותרת את הבעיה**.
- הארגון:
 - לא תמיד מוכן לשלם
 - לא תמיד יכול להחליף מערכת
- תפקיד ה-CISO -
 - להציג סיכון
 - להציע חלופות (פיצוי, ניטור, הקשחה)
 - לא להסתתר מאחורי "זה ידוע"

7. כשל, טעות ואירוע אבטחת מידע

- אירועי אבטחת מידע יקרו לכל CISO.
- כשל $\neq$ בהכרח רשלנות.
- דוגמאות:
 - Zero-day - כשל קיים גם אם לא היה ידוע
 - פשינג - גם עם הדרכה אין 100%
- השאלה החשובה:
האם ניהל הסיכון היה סביר?

8. מודעות משתמשים – כלי הפחתת סיכון

- רוב מתקפות הכופר עדיין מתחילות ב - Email.
- אם הסיכון הוא "עובד ילחץ:"
 - פתרון = מודעות, הדרכה, תרגול
- מודעות $\neq$ הבטחה, אבל כן מקטינה הסתברות.

9. הזדהות ואימות – עקרונות

שלושת גורמי האימות:

1. משהו שאתה יודע – סיסמה
2. משהו שיש לך - OTP / SMS / Authenticator
3. משהו שאתה – ביומטריה

נקודה קריטית:

- בביומטריה אין 100% דיוק
- תמיד איזון בין:
 - False Acceptance
 - False Rejection

10. אתיקה מקצועית של CISO

- תפקיד האבטחה מגן על החברה האנושית, לא רק על הארגון.
- עקרונות:
 - יושר
 - שקיפות
 - לא להסתיר סיכונים
 - לא "לייפוט" מציאות
- ההחלטה הסופית היא של ההנהלה – אבל האחריות המקצועית על הצפת הסיכון היא של ה-CISO.

21.12.2025

שיעור 2 – ניהול סיכונים, בקורות, משילות וציות (GRC)

מטרת השיעור

להבין כיצד ארגון:

- מזהה סיכונים
- מנהל סיכונים (לא רק מאתר אותם)
- משתמש בבקורות
- פועל תחת משילות, (Governance) ניהול (Management) וציות (Compliance)
- בונה מסמכי מדיניות ונהלים בצורה נכונה

חלק א' – ניהול סיכונים (Risk Management)

סקר סיכונים ≠ ניהול סיכונים

- **סקר סיכונים:** איתור חולשות ואיומים קיימים (מה לא תקין עכשיו).
- **ניהול סיכונים:**
טיפול גם ב:
 - סיכונים קיימים
 - סיכונים פוטנציאליים שהארגון לא מוכן שיתרחשו כלל

דוגמה:

- סקר: נמצא חור אבטחה באתר
- ניהול: גם מניעת מתקפת כופר שעדיין לא קרתה

מושגי יסוד

- **נכס – (Asset)** מה שחשוב לארגון (מידע, מערכת, כסף, מוניטין)
- **איום – (Threat)** מה עלול לפגוע בנכס
- **חולשה – (Vulnerability)** נקודת תורפה שמאפשרת לאיום להתממש
- **סיכון – (Risk)** שילוב של איום + חולשה + השפעה (סבירות התממשות כפול נזק האפשרי)

התמודדות עם סיכון (Risk Treatment / Risk Response)

“גם קבלת סיכון היא החלטה ניהולית”.

לאחר שזוהה סיכון והוערכה רמתו, הארגון חייב לבחור איך הוא מתמודד איתו. זו לא שאלה תאורטית – אלא החלטה ניהולית מודעת.

בשיעור הוסבר כי קיימות ארבע דרכי התמודדות עיקריות עם סיכון.

1. הימנעות מסיכון (Risk Avoidance)

ביטול הפעילות שיוצרת את הסיכון.

מתי משתמשים?

כאשר:

- הסיכון גבוה מאוד
- ואין דרך סבירה לצמצם אותו
- או שהפעילות אינה חיונית לארגון

דוגמה:

- לא לפתוח שירות דיגיטלי חדש
- לא לאסוף סוג מסוים של מידע
- לא לעבוד עם ספק מסוכן

* זהו הפתרון הכי "בטוח" – אבל גם הכי מגביל עסקית.

2. הפחתת סיכון (Risk Mitigation / Reduction)

צמצום הסיכון באמצעות **בקורות**.

איך?

- הוספת אמצעי אבטחה
- נהלים
- הדרכות
- טכנולוגיה
- שכבות הגנה

דוגמה:

- הצפנה
- Firewall
- הרשאות
- ביטוח
- בקרה אנושית

* זו דרך ההתמודדות הנפוצה ביותר בארגונים.

3. העברת סיכון (Risk Transfer)

העברת ההשפעה הכלכלית של הסיכון לגורם אחר.

איך?

- ביטוח
- חוזה
- ספק חיצוני
- סעיפי שיפוי

דוגמה:

- ביטוח סייבר
- חוזה SLA עם ספק ענן
- העברת אחריות משפטית בחוזה

* הסיכון לא נעלם – רק לא נשאר כולו אצלך.

4. קבלת סיכון (Risk Acceptance)

החלטה מודעת לא לטפל בסיכון.

מתי זה קורה?

כאשר:

- הסיכון נמוך
- עלות הטיפול גבוהה מהנזק האפשרי
- הארגון מוכן "לחיות עם זה"

תנאי חשוב:

ההחלטה חייבת להיות:

- מודעת
- מתועדת
- מאושרת ע"י הנהלה

*סיכון שלא טופל בכוונה $\neq$ הזנחה.

סיכום בטבלה (כמו בבוחן)

דוגמה	מהות	דרך התמודדות
לא לאסוף מידע	ביטול הפעילות	הימנעות
הצפנה	הוספת בקורות	הפחתה
ביטוח	העברת נזק	העברה
סיכון נמוך	חיים עם הסיכון	קבלה

משפט מפתח מהשיעור (חשוב למבחן)

"אין סיכון שלא בוחרים איך להתמודד איתו".

חלק ב' – סוגי סיכונים

1. סיכון שורשי / טוטאלי (Inherent / Total Risk)

- הסיכון המקסימלי בהיעדר בקורות
- Worst Case Scenario

דוגמאות:

- משרד בשווי מיליון ₪ ← שריפה מלאה
- הימור בקזינו על \$100 ← הפסד מלא

2. סיכון שיורי (Residual Risk)

- הסיכון לאחר הפעלת בקורות
- כמה נשאר להפסיד אם הבקורות עובדות

דוגמאות:

- מחסן עם מחיצות אש ← נשרף רק חצי
- ביטוח ← לא כל הנזק נשאר על הארגון

כלל חשוב:

*אם אין בקורות – הסיכון השורשי = הסיכון השיורי

חלק ג' – בקורות (Controls)

הגדרה

כל דבר שמפחית סיכון – פיזי, טכנולוגי או ניהולי

דוגמאות:

- מנעול
- מצלמה
- נוהל
- ביטוח
- שלט
- כלב
- הדרכה

סוגי בקורות (לפי אופי)

1. ניהוליות (Administrative)

- נהלים, חוזים, מדיניות, שילוט
- 2. **טכנולוגיות (Technical / Logical)**
 - תוכנה, חומרה, הצפנה Firewall ,
- 3. **פיזיות (Physical)**
 - גדר, שומר, דלת, כלב

*** עקרון חשוב**

Defense in Depth – שכבות הגנה
לא להסתמך על בקרה אחת בלבד

חלק ד' – קטגוריות בקרות (לפי מטרה)

1. Preventive – מונעת

מונעת את התממשות הסיכון
דוגמה: סגירת פורטים, גדר

2. Detective – מזהה

מזהה אירוע בזמן אמת
דוגמה: מצלמות, IDS, כלב

3. Deterrent – מרתיעה

מרתיעה מפעולה
דוגמה: שילוט "המקום מצולם", איום בענישה

4. Directive – מנחה

מכוונת להתנהגות רצויה
דוגמה: הדרכות, שלטים

5. Corrective – מתקנת

תיקון נקודתי לאחר טעות
דוגמה: הודעת שגיאה, תיקון הגדרה

6. Recovery – שיחזור

החזרת מערכת/פעילות לאחר אירוע משמעותי
דוגמה, DRP: גיבויים, חידוש פעילות

7. Compensating – מפצה

חלופה לבקרה שלא קיימת / לא זמינה
דוגמה: אין כלב ← מנעול חכם

*כלל מפתח:

בקרה יכולה להשתייך לכמה קטגוריות – הסיווג נקבע לפי המטרה העיקרית

חלק ה' – Governance, Management, Compliance (GRC)

Governance – משילות

- קובע מה נכון לארגון
- חזון, יעדים, כיוון
- רמת דירקטוריון / הנהלה
- לא עוסק ב"איך"

דוגמה:

- "הארגון מחויב לאבטחת מידע ופרטיות"

Management – ניהול

- קובע איך מיישמים
- תוכניות עבודה, נהלים, בקורות

דוגמה:

- איך מגבים, איך מנהלים סיסמאות

Compliance – ציות

- עמידה בחוקים ותקנים
- נקבע ע"י הארגון / מנכ"ל

דוגמאות:

- GDPR, ISO, PCI, NIST

GRC

שילוב של:

- Governance
- Risk Management
- Compliance

הבטחת מידע היא **חלק מ GRC** - לא מערכת נפרדת.

חלק ו' – סדר היררכיית מסמכים ארגוניים

1. Policy – מדיניות/ משילוט

- לרוב הוצא/מאושר ע"י הנהלה
- רמה גבוהה
- מה הארגון מחויב לעשות
- מסמך מחייב
- משתנה לעיתים רחוקות

2. Standard – סטנדרט

- דרישות מדויקות
- חובה
- דוגמה: סיסמה מינימום 12 תווים

3. Baseline – קו בסיס

- דרישת מינימום
- מותר להחמיר

4. Guideline – הנחיה

- המלצה
- לא מחייבת
- נתונה לפרשנות

5. Procedure – פרוצדורה

- Step-by-step
- איך מבצעים בפועל
- משתנה בתדירות גבוהה

כלל חשוב

- **Policy גובר על Procedure**
- "Policy = מה"
- "Procedure = איך"

מדיניות שחייבת אישור דירקטוריון (בד"כ)

1. מדיניות אבטחת מידע
2. מדיניות פרטיות
3. מדיניות המשכיות עסקית

חלק ז' – תקנים ורגולציה (יישום מעשי)

- ארגון לא "רוצה תקן" – הוא רוצה פעילות עסקית
- התקן הוא תוצאה של הבחירה העסקית

כלי מרכזי שהוצג:

SCF – Secure Controls Framework

- Excel שממפה בקורות מול:
 - ISO
 - NIST
 - PCI
 - SOC2
 - GDPR
 - רגולציות מדינתיות

מאפשר:

- זיהוי חפיפות
- איתור פערים
- עבודה חכמה מול ריבוי תקנים

שאלות בוחן שחזרו בשיעור

1. אם Procedure ו Policy – סותרים – מי גובר?
Policy
2. מה מטרת מדיניות אבטחה?
Governance, ניהול סיכונים ו Compliance-
3. ההבדל בין Corrective ל – Recovery?
 - Corrective – תיקון נקודתי
 - Recovery – החזרת מערכת/פעילות מלאה

משפטי מפתח לזכירה

- “סקר סיכונים מגלה – ניהול סיכונים מנהל”
- “אין הפחתת סיכון בלי בקורות”
- “Policy” קובע “מה?” Procedure, קובע “איך?”
- “Residual Risk” = סיכון אחרי בקורות
- “Governance” לא עוסק באיך

24.12.2025

שיעור שלוש

תקציר שיעור – ניהול סיכונים, בקורות, משילות והמשכיות עסקית

1. סקר סיכונים מול ניהול סיכונים – הבחנה מרכזית

- **סקר סיכונים**: פעולה נקודתית שמטרתה לאתר ליקויים קיימים.
- **ניהול סיכונים**: תהליך מתמשך שמנהל סיכונים לאורך זמן, כולל סיכונים עתידיים ושינויים בפעילות.

*עיקרון חשוב:

אין חובה להביא סוקר חיצוני – ארגון עם ידע יכול לבצע סקרי סיכונים בעצמו.

2. מושגי יסוד בניהול סיכונים

- **Asset** - נכס (מידע, מערכת, תהליך, שירות או מוניטין).
- **Threat** - איום (גורם שעלול לפגוע בנכס).
- **Vulnerability** - חולשה (נקודת תורפה שמאפשרת לאיום להתממש).
- **Risk** - סיכון (שילוב של איום, חולשה והשפעה).

3. סיכון אינהרנטי וסיכון שיורי

- **Inherent Risk** – רמת הסיכון ללא בקורות.
- **Residual Risk** – הסיכון שנשאר לאחר הפעלת בקורות.

*כלל מפתח:

אם אין בקורות – הסיכון השיורי שווה לסיכון האינהרנטי.

4. בקורות (Controls)

סוגי בקורות לפי אופי

- **ניהוליות** – מדיניות, נהלים, חוזים.
- **טכנולוגיות** – הצפנה, מערכות אבטחה, ניטור.
- **פיזיות** – גישה פיזית, מצלמות, שמירה.

סוגי בקורות לפי מטרה

- Preventive – מונעת
- Detective – מזהה
- Corrective – מתקנת
- Recovery – שיקום
- Deterrent – מרתיעה
- Directive – מנחה
- Compensating – חלופית

עקרונות הגנה

- **Defense in Depth** – שכבות הגנה מרובות.
- **Good Enough Security** – איזון בין עלות, סיכון ותועלת (לא אינסוף שכבות).

5. דרכי טיפול בסיכון (Risk Treatment)

1. **Avoid** – הימנעות מהפעילות.
2. **Mitigate** – הפחתה באמצעות בקורות.
3. **Transfer** – העברה (ביטוח, ספק).
4. **Accept** – קבלה מודעת של הסיכון.

6. Governance, Risk, Compliance (GRC)

- **Governance** – קביעת כיוון וגבולות (הנהלה, דירקטוריון).
- **Risk Management** – ניהול וניתוח סיכונים.
- **Compliance** – עמידה ברגולציה ותקנים.

הבחנה חשובה:

ICISO DPO – **מייעצים ומציגים סיכונים** – הם אינם מקבלי ההחלטות.

7. היררכיית מסמכים ארגונית

1. Policy – מדיניות
2. Standard – סטנדרט מחייב
3. Baseline – רף מינימום
4. Guideline – הנחיות
5. Procedure – נוהל עבודה

***Policy גובר על Procedure .**

8. ועדות וניגוד עניינים

- **DPO לא יכול להיות היועץ המשפטי** (ניגוד עניינים בין חובת סודיות לחובת דיווח).
- ועדת היגוי בוחנת:
 - יישום בפועל
 - תכנית עבודה
 - סיכונים מתפרצים ושינויים בפעילות
- תדירות הוועדות – לפי קצב השינויים בארגון.

9. ניהול אירועים ומשברים

Incident / Crisis Management

- הקמת **CMT – Crisis Management Team** (הנהלה בכירה).
- ההנהלה מכריזה על מצב חירום ו-BCP.

שלבי ניהול אירוע

1. היערכות
2. זיהוי וניתוח
3. הכלה
4. סילוק
5. התאוששות
6. תחקור

10. המשכיות עסקית – מושגים קריטיים

- **BCP** – Business Continuity Plan
- **BCMS** – מערכת ניהול המשכיות עסקית
- **BIA** – Business Impact Analysis
- **RTO** – זמן חזרה לפעילות
- **RPO** – נקודת שחזור מידע
- **MTD** – זמן השבתה מירבי
- **SDO** – Service Delivery Objective (רמת שירות חלופית)

*הערה חשובה:

את הערכים (RTO, RPO, SDO) קובעת ההנהלה – לא אנשי האבטחה.

11. סיווג נכסים (Classification)

- שלב ראשון: רשימת נכסים.
- ניתן להגיע אליה דרך:
 - מיפוי נכסים
 - BIA או ניתוח השפעה עסקית

12. מסר מרכזי של השיעור

- ניהול סיכונים הוא תהליך מתמשך.
- בקורות נועדו להפחתת סיכון – לא לאפס אותו.
- החלטות סיכון הן החלטות הנהלה.

- אבטחה, פרטיות והמשכיות – תחום אחד מחובר.

השוואות בין מושגים קרובים - CISO / DPO

1. סקר סיכונים מול ניהול סיכונים

היבט	סקר סיכונים	ניהול סיכונים
אופי	פעולה נקודתית	תהליך מתמשך
מטרה	גילוי בעיות קיימות	שליטה בסיכון לאורך זמן
זמן	חד-פעמי / תקופתי	רציף
תוצר	רשימת ליקויים	החלטות ניהוליות
אחריות	לרוב מקצועית	הנהלה

*תובנה:

סקר סיכונים שואל "מה לא תקין עכשיו?"
ניהול סיכונים שואל "איך הארגון חי עם סיכון גם מחר?"

2. Asset לעומת Data

היבט	Asset (נכס)	Data (מידע)
הגדרה	כל מה שחשוב לארגון	סוג אחד של נכס
דוגמאות	מערכת, שירות, מוניטין	מידע אישי, לוגים
שימוש בניהול סיכונים	בסיס לכל התהליך	חלק ממיפוי נכסים

*תובנה:

לא כל Asset הוא Data,
אבל כל Data הוא Asset.

Vulnerability לעומת Threat 3.

היבט	Threat(איום)	Vulnerability (חולשה)
מה זה	גורם תוקף	נקודת תורפה
דוגמה	האקר	מערכת לא מעודכנת
קיום עצמאי	כן	כן
סיכון נוצר	רק כשיש גם וגם	רק כשיש גם וגם

משפט לזכור:

אין סיכון בלי איום וגם חולשה.

Inherent Risk לעומת Residual Risk 4.

היבט	סיכון אינהרנטי	סיכון שיורי
מתי נמדד	לפני בקורות	אחרי בקורות
משמש ל-	הבנת Worst Case	קבלת החלטות
מי קובע	ניתוח מקצועי	הנהלה

*תובנה:

Residual Risk הוא הסיכון שההנהלה בחרה לחיות איתו.

Risk Treatment לעומת Control 5.

היבט	Control (בקרה)	Risk Treatment
מה זה	אמצעי	החלטה
דוגמה	הצפנה	הפחתת סיכון
מי מבצע	IT / אבטחה	הנהלה
תפקיד	לצמצם סיכון	לבחור דרך התמודדות

*תובנה עמוקה:

בקרה היא הכלי-

Risk Treatment הוא הכיוון.

Mitigation 6. לעומת Transfer

היבט	הפחתה (Mitigation)	העברה (Transfer)
מה קורה לסיכון	קטן	נשאר
מי סופג נזק	הארגון	צד שלישי
דוגמה	הצפנה	ביטוח סייבר

משפט זהב:

*ביטוח לא מונע אירוע – רק משלם עליו.

Negligence לעומת Acceptance 7.

היבט	קבלת סיכון	הזנחה
החלטה מודעת	כן	לא
תיעוד	חובה	אין
אישור הנהלה	כן	לא
לגיטימיות	כן	לא

*תובנה עמוקה:

קבלת סיכון = החלטה ניהולית

הזנחה = כשל ניהולי

Management לעומת Governance 8.

היבט	Governance	Management
שאלה	מה נכון	איך מבצעים
רמה	הנהלה / דירקטוריון	דרג ביצוע
מסמכים	Policy	Procedure

CISO / DPO לעומת הנהלה 9.

היבט	CISO / DPO	הנהלה
תפקיד	ייעוץ והצגת סיכונים	קבלת החלטות
סמכות	מקצועית	ניהולית
אחריות	מקצועית	משפטית

משפט מבחן קלאסי:

CISO מציג סיכון – הנהלה מחליטה.

BCP 10 לעומת BCMS

היבט	BCP	BCMS
מה זה	תוכנית	מערכת ניהול
סטטי/דינמי	יחסית סטטי	מתמשך
כולל	תרחישים	מדיניות, בקרה, שיפור

RTO 11 לעומת RPO לעומת SDO

מושג	שאלה שהוא עונה
RTO	תוך כמה זמן חוזרים
RPO	כמה מידע מותר לאבד
SDO	באיזה רמת שירות זמנית עובדים

***תובנה:**

RTO ו-RPO - עוסקים בחזרה
SDO עוסק בחיים באמצע

משפטי מפתח מהשיעור

- "אין אבטחה מושלמת – יש אבטחה מספקת".
- "בקרה אחת היא נקודת כשל".
- "ניהול סיכונים הוא שיח עם הנהלה, לא עם שרתים".
- "מי שלא מחליט על סיכון – מקבל אותו כברירת מחדל".

28.12.2025

שיעור 4 - קבלת החלטות, אחריות ניהולית, פרטיות ואבטחת מידע כניהול סיכון

השיעור עוסק בהפיכת אבטחת מידע ופרטיות משיח טכני – לשיח ניהולי, עסקי ואחראי.

מטרת השיעור

להבין ש:

- אבטחת מידע ופרטיות אינן בעיה טכנולוגית
- אלא בעיה ניהולית-עסקית
- שבה ההנהלה היא הגורם המחליט והאחראי

1. אחריות ניהולית – הבחנה קריטית

מי אחראי למה?

- **CISO / DPO**
 - מזהים סיכונים
 - מנתחים השפעה
 - מציגים חלופות
 - לא מקבלים החלטות עסקיות
- **הנהלה / דירקטוריון**
 - מקבלים החלטות סיכון
 - מאשרים קבלת סיכון
 - אחראים משפטית ורגולטורית

משפט מפתח מהשיעור:

“מי שלא מחליט על סיכון – מקבל אותו כברירת מחדל”.

2. קבלת סיכון – (Risk Acceptance) לא בשל

מהי קבלת סיכון?

החלטה מודעת של ההנהלה:

- לא להשקיע משאבים נוספים
- ולהמשיך לפעול למרות סיכון קיים

תנאים הכרחיים:

- הסיכון הוצג בצורה ברורה
- ההשלכות הובנו
- ההחלטה **תועדה**
- קיימת בעלות ניהולית על הסיכון

קבלת סיכון ≠ הזנחה

3. רגולציה וציות – איך זה מתחבר לניהול סיכונים

עיקרון יסודי:

רגולציה לא מחייבת אפס סיכון
היא מחייבת:

- מודעות
- ניהול
- תיעוד
- סבירות

דוגמה:

- אין חובה למנוע כל דליפת מידע
- יש חובה להראות:
 - שננקטו אמצעים
 - שנעשה ניהול סיכונים
 - שנלמדו לקחים

4. פרטיות כחלק מניהול סיכונים

Privacy ≠ Legal only

פרטיות כוללת:

- סיכונים עסקיים
- סיכונים מוניטין
- סיכונים לקוחות
- סיכונים רגולציה

ולכן:

- DPO הוא חלק מ-GRC
- ולא "איש משפט עם מייל"

5. עקרון השקיפות (Transparency)

מה נדרש בפועל?

- שהארגון יוכל להסביר:
 - איזה מידע נאסף
 - למה
 - כמה זמן
 - עם מי משתפים
 - ואיך מגינים עליו

הבחנה חשובה:

גם אם הפעילות חוקית –
חוסר שקיפות = סיכון.

6. מימוש זכויות

זכויות נושא מידע:

- עיון
- תיקון
- מחיקה
- התנגדות
- הגבלה

הדגש בשיעור:

- לא מספיק "מייל כללי"

- נדרש מנגנון ברור, מתועד וישים
- זמני תגובה הם חלק מניהול הסיכון

7. אבטחת מידע "Good Enough Security" –

עיקרון מרכזי:

אין אבטחה מוחלטת.
יש אבטחה:

- סבירה
- פרופורציונלית
- מותאמת לסיכון

דוגמה:

- לא כל מערכת דורשת אותה רמת הגנה
- ההשקעה נקבעת לפי:
 - ערך הנכס
 - רמת הסיכון
 - השפעה עסקית

8. קשר בין Privacy, Security ו-Business-

השיעור חיבר בין:

- פרטיות
- אבטחת מידע
- המשכיות עסקית
- קבלת החלטות הנהלה

מסר מרכזי:

אירוע פרטיות הוא לעיתים:

- אירוע אבטחה
- אירוע תפעולי
- אירוע מוניטין
- ולעיתים משבר עסקי מלא

9. אירועים, תחקור ולמידה

לאחר אירוע:

- לא מחפשים "אשם"
- מחפשים:
 - כשל תהליכי
 - פער בבקורות
 - חוסר החלטה ניהולית

תחקור איכותי כולל:

- מה קרה
- למה זה קרה
- מה לא עבד
- מה משנים קדימה

10. "בוחנים" – שאלות בסגנון מבחן

שאלה:

מי אחראי לקבלת סיכון?
✓ההנהלה

שאלה:

האם קבלת סיכון היא כשל?
Xלא – אם היא מודעת ומתועדת

שאלה:

האם רגולציה דורשת אפס אירועים?
Xלא – דורשת ניהול סיכונים סביר

שאלה:

האם DPO מקבל החלטות עסקיות?
Xלא

11. משפטי מפתח

- "פרטיות היא ניהול סיכונים – לא סעיף משפטי".
- "אין אבטחה מושלמת – יש אבטחה סבירה".

- “סיכון שלא נוהל – הוא סיכון שהארגון בחר לקבל”.
- “רגולטור בודק תהליך, לא שלמות”.